

- **Backend development (or server-side development):** Backend²¹¹ development can be facilitated through hardware or software-based solutions. Backend development includes developing databases, internal APIs, business logic, microservices, web integration, servers, and server-based utilities. Users interact directly with the front end to communicate and engage with the backend, which is not visible to end users. Backend developers should understand front-end development and vice versa. Without that understanding, the risk of noncompliance with laws and regulation increases. For example, financial institution customers rely on loan calculators to provide accurate results relevant to their input scenario. Visible and correct results are only possible if the user interface is clear (front-end development) and the calculations are accurate (backend development).
- **Big data development:** Big data development focuses on using, organizing, and maintaining large amounts of data that may originate from many sources. Big data development includes building data mining, data visualization, and quantitative analysis tools. In addition to developing specific tools, big data developers work with analysts to help them decide whether a set of data are appropriate for their analytics. Big data development can result in maintaining petabytes of complex unstructured, semi-structured, and structured data without rigid schemas. When appropriately controlled, big data can enable cost-effective processing of massive volumes of data, support multiple concurrent queries and other analytics tasks, and rapidly generate results. However, if big data environments are not adequately controlled, costs may increase rapidly, and the examined entity may rely on inaccurate information for business decisions. For additional information on big data, refer to the *FFIEC IT Handbook's* "[Architecture, Infrastructure, and Operations](#)" booklet.

The following subsections of this booklet provide more information on additional development types, including model development and database development.

V.D.1 Model Development

For purposes of this discussion, “model” refers to a quantitative method, system, or approach that applies statistical, economic, financial, or mathematical theories, techniques, and assumptions to process input data into quantitative estimates.²¹² A model consists of three components: an information input component, which delivers assumptions and data to the model; a processing component, which transforms inputs into estimates; and a reporting component, which translates the estimates into useful business information. Models meeting this definition may be used in the following:

- Analyzing business strategies.
- Informing business decisions.
- Identifying and measuring risks.
- Valuing exposures, instruments, or positions.
- Stress testing.

²¹¹ Merriam-Webster defines “[backend](#)” as “the part of a software system that is not usually visible or accessible to a user of that system.”

²¹² For purposes of this discussion, the term “model,” is used as described in joint agency guidance, FRB SR Letter 11-7, “[Guidance on Model Risk Management](#),” and OCC Bulletin 2011-12, “[Sound Practices for Model Risk Management: Supervisory Guidance on Model Risk Management](#).”

- Assessing capital adequacy.
- Managing client assets.
- Measuring compliance.
- Maintaining the formal control apparatus of the bank.
- Meeting financial or regulatory reporting requirements.
- Issuing public disclosures.

V.D.2 Database Development

Databases are digital repositories of data designed to be accessed, managed, and updated. They can be internally developed or purchased from third parties. Commonly used database models include hierarchical, networked, relational, object-relational, and nonrelational. Developers should understand the different types, structures, and uses of databases to effectively mitigate database development risks. To do this, it is important to understand the benefits, limitations, and appropriate controls for the type of database used. Examples of risks developers of databases should consider include the following:

- Data errors and omissions.
- Inappropriate database access privileges.
- Misuse of legitimate privileges.
- Database injection attacks (e.g., SQL injection).
- Malware.
- Storage media exposure (e.g., backups).
- Exploitation of vulnerable databases (e.g., failure to patch and maintain the database).
- Unmanaged sensitive data (e.g., failure to maintain an accurate database inventory that includes each database's content and the content's sensitivity).
- Human error (e.g., failure to apply security controls, enforce policies, or implement appropriate incident response processes).

Potential mitigation strategies include the following:

- Maintaining a database inventory that includes the database location(s), contents, and sensitivity.
- Assessing databases for any vulnerabilities.
- Managing user access rights (e.g., removing user access and privileges when access is no longer required for business purposes).
- Logging and monitoring database access and usage to identify patterns and help detect data leakage, unauthorized or significant activity, and system and component attacks in real time.
- Blocking inappropriate web requests.
- Backing up the databases.
- Encrypting databases.
- Training database developers on their security-related development responsibilities, including identification of potential information security risks and appropriate mitigation practices.

Prudent practices include choosing databases that meet business and other stakeholder objectives and implementing controls, including access controls, to protect the data consistent with their criticality and sensitivity. Additional database design and selection considerations are flexibility, scalability, data integrity, and retrieval efficiency.

VI ACQUISITION

Action Summary

Management should establish acquisition processes that are commensurate with the entity's business and procurement needs. Management should also assess and mitigate procurement risks associated with an entity's overall strategic, regulatory, and operational risks.

Examiners should review the following:

- Project requests and plans for one or more recent acquisitions.
- Strategic and business plans, risk assessments, due diligence activities, and acquisition-related meetings with minutes.
- Contracts and licensing agreements.
- Acquisition policies, standards, and procedures, including evaluation criteria and documentation maintenance practices.
- Acquisition training and entity guidance for stakeholders.
- Acquisition and procurement-related audits.

NIST defines “acquisition” as “all stages of the process of acquiring a system, product, or service, beginning with the process for determining the need for that system, component, product, or service and ending with contract completion and closeout.”²¹³ While acquisition and procurement are terms often used interchangeably, for purposes of this booklet acquisition refers to the overarching process and procurement refers to the specific steps to obtain the system, product, or service. To effectively manage the risks inherent in acquired systems, components, products, or services, entity personnel identify key roles and responsibilities. For example, once management completes contract negotiation and takes control of the system, component, product, or service, management determines the activities related to and responsibilities for oversight (e.g., entity's third-party or enterprise risk management office).

An entity may acquire technology or technology services from a third party, rather than developing it in-house. An entity may use or acquire systems, components, products, and services from various sources, including internal development teams, technology and software development firms, co-sourced arrangements, open-source repositories, and commercial sources. When an entity purchases systems, components, products, or services, effective management ascertains whether the product specifications are “fit for purpose” and meet the entity's requirements, whether purchasing directly from the OEM partners or a secondary market. This should be addressed in agreements with supply chain partners.

The acquisition of system, components, products, and services (versus in-house development) poses certain risks at each step of the acquisition process that should be assessed and mitigated. Risks associated with the third-party product or service may vary depending upon the specific

²¹³ Refer to [NIST Glossary](#).

situation. These may include strategic (e.g., the system does not align with business needs), regulatory (e.g., the solution does not consider GLBA), and operational risks (e.g., the provider does not have an adequate testing environment or sufficient resources to maintain the solution). In addition, there may be third-party risk management concerns,²¹⁴ weaknesses in security controls, or other operational weaknesses at the third-party provider.

An entity may mitigate the risks associated with acquisition in several ways. The following are examples of effective risk mitigation:

- Develop policies, standards, and procedures to effectively carry out the entity's procurement processes aligned with the entity's acquisition activities.
- Perform potential supplier due diligence reviews.²¹⁵ Due diligence rigor should align with a risk assessment that identifies the criticality of the business function supported, the information sensitivity the system or component stores or processes, business function complexity, and external factors such as the supplier's location and ownership.
- Implement contract and licensing processes for all acquisitions, particularly for more complex relationships. An entity's processes should include contract and license review to help ensure that the rights, responsibilities, and accountability of each party are clear.

A structured procurement process (such as the procurement steps in figure 8) is likely to produce more consistent and sustainable results across an entity over time. The more critical the system, component, and service being procured the more important that each procurement step is successfully completed.

In the example in figure 8 below, the procurement process begins with the identification of an entity's business need for procuring a system, component, or service. Then management may engage in the following:

- **Planning.** Planning what information will be needed to procure the best system, component, or service, and requesting information from the project team and key stakeholders.
- **Defining requirements.** From planning and information provided, clearly defining what requirements are necessary.
- **Solicitation.** Requesting quotes or proposals.
- **Evaluation and selection.** Evaluating proposals and determining the best choice.
- **Contract negotiation and award.** Determining contract requirements and responsibilities, and which risks will not be covered in contract.

²¹⁴ Refer to the following guidance: [Interagency Guidance on Third-Party Relationships: Risk Management](#), also noted in OCC Bulletin 2023-17, "[Third-Party Relationships: Interagency Guidance on Risk Management](#)"; FDIC FIL-29-2023, "[Interagency Guidance on Third-Party Relationships: Risk Management](#)"; and FRB SR Letter 23-4, "[Interagency Guidance on Third-Party Relationships: Risk Management](#)." Also see CFPB Compliance Bulletin and Policy Guidance 2016-02, "[Service Providers](#)."

²¹⁵ Refer to NIST SP 800-53, rev. 5, SR-3, [Supply Chain Controls and Processes](#), notes that rigorous due diligence includes research on potential suppliers or products, as well as their upstream dependencies (e.g., fourth- and other parties beyond third-party suppliers), which can help enterprises avoid single points of failure in their supply chains. The results of this research can be helpful in shaping the sourcing approach and refining requirements.

- **Vendor management and ongoing administration.** Oversight and maintenance of the relationship, if ongoing.
- **Preparing for the off-ramp.** EOL or upgrade of system, component, or service.

Figure 8: Procurement Steps: Example



An effective procurement process helps management and personnel to address each step in the process, communicate and meet combined stakeholder requirements, select appropriate systems and components, and support the entity's overall business objectives. Additionally, an effective process helps minimize confusion (e.g., by identifying minimum requirements) and promotes coordination in the supply chain (e.g., by achieving efficiencies using one OEM for multiple products).

Specific procurement risks to address include the following:

- Actual costs being materially higher than budget.
- Procured system, component, or service does not meet all stakeholder's requirements.
- Due diligence does not reveal a material third-party deficiency.
- Procured system does not interoperate with existing systems.
- Procurement process informality leads to inconsistent system, component, and service selection over time.
- Contract or license does not specify characteristics critical to system, component, and service success.
- Lack of visibility into supply chain partners for identification of weaknesses (e.g., security, interoperability, or incident response).

VI.A Acquisition Policies, Standards, and Procedures

Acquisition policies, standards, and procedures that are enforced create acquisition consistency across the entity. Well-communicated and enforced policies, standards, and procedures are important for the acquisition process to help determine the appropriate technology for new IT

procurement requests or requests for significant updates to current systems and components. Without adequate policies, standards, and procedures, management may expose the entity to the following:

- Procurement of a system or component that does not address the business need.
- Products or services that fail to protect the confidentiality, integrity, availability, and resilience of the entity's systems and components, which may adversely affect other systems in the entity's supply chain.
- Noncompliance with legal and regulatory requirements (e.g., Information Security Standards, Bank Service Company Act).
- Inadequate contracts and licensing agreements, due to failure to communicate and involve key stakeholders (e.g., IT, information security, privacy, legal, and compliance personnel).

An effective entity's acquisition policies, standards, and procedures address the following:

- Information requests, such as requests for information (RFI) and requests for proposals (RFP) to third parties. Responses to these requests provide the entity with vital information for identifying the best provider solution. Requests for quotes (RFQ) are also used before final selection to obtain the best pricing. For additional information on RFIs, RFPs, and RFQs, refer to the "[Solicitation](#)" section in this booklet.
- Third-party due diligence²¹⁶ includes the following:
 - Comprehensively assessing risks associated with third-party relationships.²¹⁷
 - Reviewing system, component, and service operational and internal controls (e.g., security and resilience controls).
 - Evaluating and selecting (including criteria for selection) a third party.
 - Checking references (e.g., through external user groups or banking association members) to ascertain current and past customer views on product and service quality.
- Specialist stakeholders' (e.g., subject matter, legal, and compliance experts) review of proposal.
- Contract negotiation to ensure that the contract contains terms amenable to the entity.
- Transferability or portability of systems, components, products, and services if a third-party relationship is discontinued.
- Contract signature authority.
- System, component, and service validation to ensure that user requirements are met before acceptance.

In some cases, management may acquire systems, components, or services from foreign-based third parties. In addition to information security risks, there are several unique risk considerations in these relationships, including the following:

²¹⁶ Refer to the following guidance: [Interagency Guidance on Third-Party Relationships: Risk Management](#).

²¹⁷ The risk assessment typically includes a third party's reputation, personnel background checks, customer service issues, financial condition, stability, and fourth-party products or services.

- **Legal.** Confusion over which country's laws will control the relationship. Additionally, it is important to consider that there may be specific U.S. laws with which the entity and its third-party service providers may need to comply (e.g., the restriction on the export of software applications employing encryption techniques).
- **Country.** The possibility that economic, social, or political conditions and events in a foreign country will adversely affect an entity's financial and business interests (e.g., financial defaults by obligors in a foreign country, nationalization of private assets, government repudiation of external indebtedness, exchange controls, or significant currency devaluations).
- **Currency (or exchange rate).** The risk that arises from the change in price of one currency in relation to another. Assets or business operations located across national borders are exposed to and affected by currency risk, creating unpredictable profits and losses, currency devaluations, and foreign exchange controls.
- **Geopolitical.** Risk associated with wars, terrorist acts, and tensions between states that affect the normal and peaceful course of international relations. For example, regime change in the country of operations may result in a loss of control over the entity's data stored in that country.
- **Resilience.** The risk that operations and assets may be undermined or destroyed by crises. This includes the capacities and resources of business systems affected by risks, stresses, and shocks. For example, if there is a disruption of utilities in a country, it may disrupt data center operations.

Management should be knowledgeable of these risks and their effects on the business before entering foreign-based third-party relationships. Therefore, effective management identifies, plans, and addresses the root causes of foreign-based risks or crises to minimize their effects on the entity's operations.

VI.B Acquisition Projects

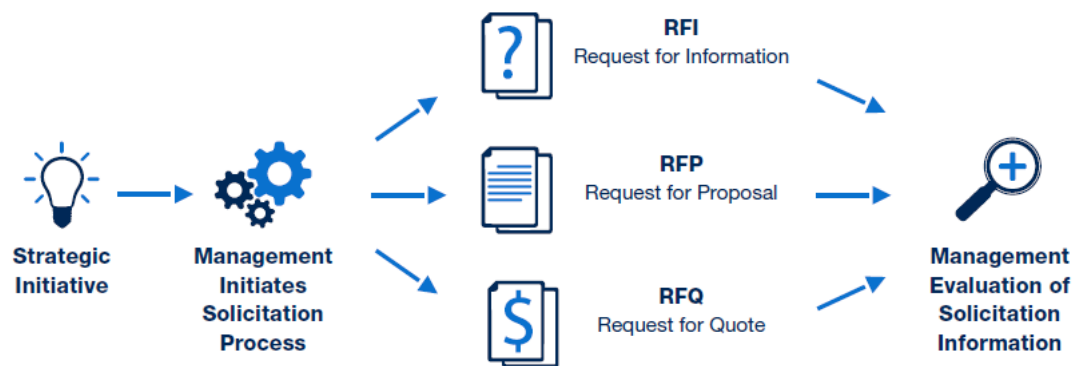
If an entity has a PMO, acquisition projects may be managed according to established entity PMO processes. Smaller or less complex entities may not have the same formality or rigor in their acquisition project processes. However, it is still important to have project guidance and procedures for the management of acquisition projects. If a procurement project request is approved, the feasibility study should clearly define the IT, information security, functional, legal, and regulatory requirements in the RFIs and RFPs that management distributes to third parties in the solicitation process for bids, including RFQs. Acquisition projects should follow the same principles as noted above throughout section IV.N. "[IT Project Management](#)."

VI.C Solicitation

For procurement projects, management follows the entity's requirements definition with solicitation for information and evaluation. These solicitations do not represent binding agreements between the entity and a third party. An entity's solicitation process generally is initiated when it has a business need or problem to solve. Management may issue RFIs to determine potential third parties with solutions available to address the business need or problem and gather information. When the entity has gathered the appropriate information and narrowed

down the number of potential third parties, management may issue an RFP to ask those third parties to propose specific solutions. This helps management evaluate and prioritize third parties and their solutions. When management has identified the third parties that can meet the business needs, it uses the RFQ to validate specific requirements and ask whether the third party is able to meet those requirements, and if so, to list all associated costs to help management determine its final selection. For smaller or less complex entities, these terms and steps may not be as clearly delineated or defined; however, management should still have a process that considers business needs, third-party solutions, specifications, and costs. A solicitation to a potential third party may involve an RFI, RFP, or RFQ, or a combination of the three if the entity chooses to move forward with a particular third party on a project, as shown in figure 9 and described in more detail below.

Figure 9: Third-Party Solicitation Types and Inputs



- RFI:** A request for information is a market research tool also referred to as a sources-sought notice that is used to obtain, for example, price, delivery, capabilities, and interest for planning purposes.²¹⁸ Management may use an RFI to identify third parties that should be targeted for more specific information or further requests. The RFI includes the entity's requirements and appropriate questions that will allow respondents to provide necessary information for stakeholders to make acquisition decisions. Third parties receive requests and provide information about their capabilities, including products or services they offer, and interest in establishing a relationship. There is no standard format for an RFI; however, a formal, well-crafted RFI may facilitate faster responses from potential third parties by providing an overview of the entity's requirements, including any specific questions for the third party. The RFI should clearly identify the entity's needs to avoid a third party's confusion with the request and omission of critical information needed for decision-making. When management receives information from the third parties, assumptions should not be made based on the responses. Instead, if appropriate, management should consider asking follow-up questions to clarify concerns or solicit more information. Additional considerations when reviewing third parties' RFI responses include the following:

- RFI format: Whether the provider followed the format specified in the RFI.

²¹⁸ For more information, refer to U.S. General Services Administration's (GSA), "[RFP, RFI, and RFQ: Understanding the Difference](#)."

- Third-party interest: Whether the third party is interested in forming a relationship.
 - Business size: Whether the third party has the resources (e.g., personnel and infrastructure) to support or provide resilience for the suggested solution.
 - Location: Proximity of the third party's location to entity locations and effect on resilience.
 - Qualifications: Whether the third party's personnel have appropriate knowledge and experience, as well as whether the entity has the personnel and training to operate the solution.
 - Subcontractor involvement: Third-party standards for subcontracted work, responsibilities and liabilities for subcontractors, third-party due diligence on subcontractors, and percentage of work to be performed by subcontractors.
 - Conflicts of interest: Whether doing business with this provider causes conflicts with other entity third-party providers, internal conflicts of interest at the entity (e.g., a relative of entity personnel works at the third party), or anticipated conflicts of interest with the third parties.
- **RFP:** A request for proposal is a solicitation method that communicates the entity's requirements and requests proposals.²¹⁹ An RFP is a formal procurement activity to solicit bids. When drafting an RFP, it is critical to communicate an entity's key system and component requirements, especially those that may incur significant costs to implement. An RFP can include a solicitation for quotes. Bids in response to an RFP provide information needed to select a provider. Information such as the description of the bidder's approach, price, and personnel expertise are helpful in differentiating between bidders to make a final selection.

Additional considerations when reviewing third parties' RFP responses include the following:

- Terms and conditions that can help management identify limitations (e.g., length of agreement, resource ceilings, and potential interruptions in service) that the third party may have.
 - Whether a third party follows the RFP format and provides the required information (e.g., cost, experience of the third party, and resilience), which indicates the third party's attention to RFP requirements.
 - Whether the third party's responses are detailed, specific, and responsive (e.g., timely and with no exceptions to the solicitation).
- **RFQ:** A request for quote is a solicitation method used to obtain price, cost, delivery, and related information from suppliers.²²⁰ An RFQ can provide more precise information for bidder comparison and budgeting. There is a potential risk in the RFQ process that bidders misunderstand when an entity is bound by an agreement and a contract is created. To

²¹⁹ For more information, refer to GSA, "[RFP, RFI, and RFQ: Understanding the Difference](#)."

²²⁰ [Ibid.](#)